

AIKB JWT 鉴权与知识库权限

- 文档编号：AIKB-SEC-003
- 默认模式：业务 API 强制 JWT
- 兼容开关：AUTH_ALLOW_LEGACY_IDENTITY_PARAMETERS=false

1. 登录边界

公开入口包括静态首页、debug 页面、健康检查、注册和登录。`/api/auth/me` 必须认证；默认配置下，其余 `/api/**` 业务接口也必须携带有效 JWT。Spring Security 使用 STATELESS Session 策略，JWT 过滤器在 `UsernamePasswordAuthenticationFilter` 之前解析 Bearer Token。

用户名密码经过 BCrypt 保存。登录成功返回 `accessToken`、`tokenType`、`expiresInSeconds` 和用户信息；默认 JWT 有效期是 86400 秒。生产环境必须替换 `JWT_SECRET`，开发默认值不能作为正式密钥。

2. 前端登录门禁

未登录访问 `index.html` 时只显示全屏登录或注册界面。页面启动后先调用 `/api/auth/me` 验证本地 Token，认证通过才加载知识库、会话等业务数据。任意业务请求返回 401 时，前端清理失效 Token、切换登录模式并

跳转到 `#login`。主动退出也走同一状态清理流程。

静态页面可以公开访问并不代表业务数据匿名开放。真正的数据边界由 Spring Security 和 Service 权限校验共同保证，前端跳转只负责用户体验。

3. legacy 身份参数

旧调试流程允许通过 `userId` 和 `department` 请求参数模拟身份。现在该能力由

`AUTH_ALLOW_LEGACY_IDENTITY_PARAMETERS` 显式控制，默认是 `false`。默认模式下，匿名请求即使伪造

`userId=test`，也会在进入 Controller 前返回 401。

只有本地兼容旧 `debug.html` 或特定测试时才临时打开 legacy 开关。共享演示、面试部署和生产化环境不应启用它。JWT 存在时，Controller 优先使用 `@AuthenticationPrincipal` 中的用户和部门，不信任请求参数。

4. 知识库数据权限

知识库的访问规则在 KnowledgeBaseService 统一执行：ownerId 等于当前用户时允许访问；知识库 department

等于当前用户部门时也允许访问；两个条件都不满足则抛出 ForbiddenException。知识库列表使用 owner 或 department 条件查询，只返回当前用户可见的数据。

文档列表、上传和聊天都应复用知识库访问校验，避免出现“不能提问但能看到文件名”或“猜到 UUID 就能读取详情”的水平越权。HTTP 401 表示没有有效身份，403 表示已经登录但没有目标资源权限。

5. 当前安全边界

当前实现已经有注册登录、JWT、BCrypt、默认强制鉴权和 owner/department 权限，但仍不是完整企业 IAM。

尚未实现 Refresh Token、Token 主动撤销、角色权限矩阵、单点登录、组织架构同步和审计告警。因此简历和

面试应描述为“实现 JWT 与基础数据权限”，不能声称已经具备完整 SSO 或零信任体系。